

SOUTENANCE – SAE 401

BouzuSec Scanner

Présenté par : BouzuCorp

*Johan Abdallah
Mohamed Droussi
Alexandre Samperez
Walid Badaoui
Nicolas Nonnenmacher*

BouzuSec Scanner

L'énergie vitale de votre site en un clin d'œil.

Des cyberattaques silencieuses peuvent vider les ressources de votre entreprise. Lancez un diagnostic visuel et compréhensible pour protéger votre avenir digital.

☒ **Mode Simple** ☐ **Mode Avancé**

Ex: tesla.com ou localhost:8080

Diagnostiquer

 **Diagnostic terminé !**

L'audit en boîte noire de **site-test** a été généré avec succès.

 **Rapport Simple**

 **Rapport Avancé**

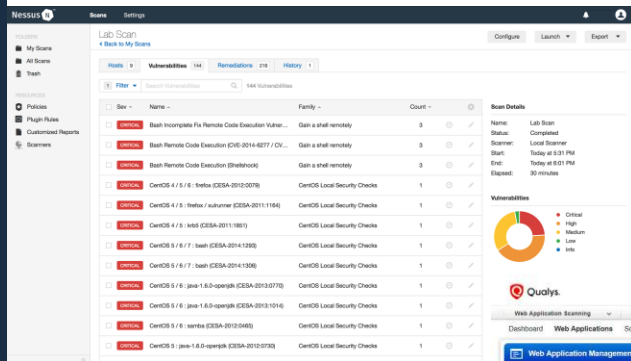
LE CONSTAT : UNE SECURITE OPAQUE ET COMPLEXE

Le problème aujourd'hui

Nessus, Qualys : licences chères

Rapports 50+ pages illisibles pour un non-expert

→ *Les dirigeants ne comprennent pas leur niveau de risque !!!*

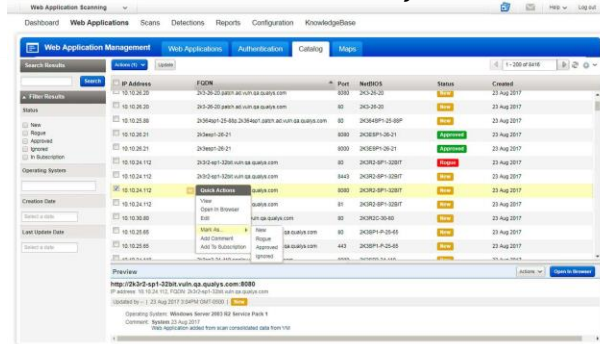


Scan Nessus

??????????????



Scan Qualys



Notre réponse : BouzuSec

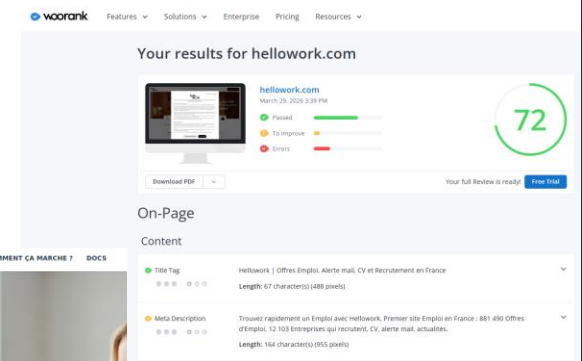
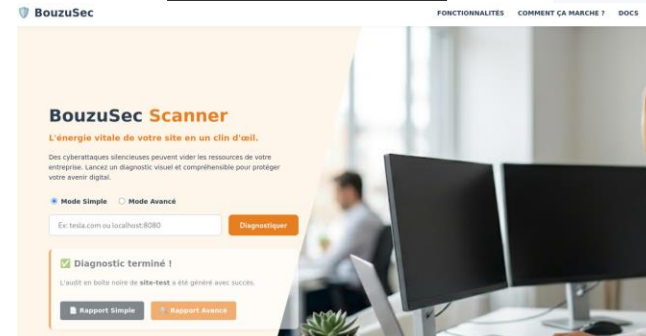
100% open-source – Gratuit – 3 commandes Docker

Rapports PDF compréhensible en 2 minutes par tout dirigeant

→ *Pensé comme WooRank, mais pour la sécurité*



Interface BouzuSec



Scan WooRank



ORGANISATION DE L'EQUIPE

Johan Abdallah

Front-End & Présentation

- Design du site
- Diaporama de présentation
- Annexe
- Gestion de projet
- Rédaction des textes de l'interface utilisateur
- Coordination des livrables
- Tests



Mohamed Droussi

Veille & Outils

- Etude de marché
- Sélection des outils
- Documentation
- Benchmark des solutions concurrentes (Nessus, Qualys, WooRank)
- Rédaction cahier des charges
- Conformité légale des scans



Alexandre Samperez

Dev

- Création d'un environnement de test Docker
- Orchestrateur des programmes
- Interfaces
- Création du site de test vulnérable
- Gestion du dépôt GitHub
- Conception de l'algo de scoring ANSSI



Walid Badaoui

Back-End & Scan

- Script Python
- Moteur orchestrateur
- Parsing sorties CLI
- Création de l'interface SaaS intuitive
- Développement du générateur PDF (rapport simple & avancé)
- Parsing et Vulgarisation des sorties CLI (GoBuster, Nikto, Nmap)



Nicolas Nonnenmacher

Veille & Outils

- Etude de marché
- Synthèse comparative
- Tests & Validation
- Documentation
- Rédaction du manuel d'installation (INSTALL.md)
- Validation fonctionnelle sur d'autres sites web vulnérables
- Rédaction du rapport de tests comparatifs



SYSTÈME DE SCORING ANSSI



La Métaphore de la Batterie

Votre site démarre à **100%** de charge. Chaque faille détectée consomme de l'énergie selon sa gravité et sa facilité d'exploitation



Sain



Modéré



Elevé

Formule Hybride du Maillon Faible

$$\text{Risque} = (\text{pire_risque} * 0,5) + (\text{moyenne_5_axes} * 0,5)$$

$$\text{Score} = 100 - (\text{risque} * 9)$$

Notre algorithme retire des points en évaluant la *gravité de l'Impact* (Mineur à Critique) face à la *Difficulté d'exploitation* de chaque faille

Système de notation ANSSI

↓ Impact Exploit. →	Très difficile	Difficile	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique

Exemple concret – site-test

`/.env exposé`
= Impact Critique * Exploitation Facile
= -8 pts sur la batterie

Echelle ANSSI

100-73% Sain

55-30% Elevé

73-55% Modéré

30-0% Critique

BOITE A OUTILS 100% OPEN SOURCE



Cartographie réseau

Ports ouverts, services actifs

Ce qu'il trouve :

Port 80 HTTP,
Sans HTTPS

Pourquoi ce choix :

Référence mondiale



Empreinte domaine

Propriétaire, dates,
Domaine, contacts

Ce qu'il trouve :

Entité anonymisée
→ Bonne pratique

Pourquoi ce choix :

Standard IETF gratuit,
scriptable



Fingerprint techno

Serveur, CMS, langages,
version

Ce qu'il trouve :

Apache 2.4.65 + PHP 8.1.34
exposés

Pourquoi ce choix :

Rapide, léger



Zones cachées

Dossiers et fichiers cachés
exposés

Ce qu'il trouve :

/admin /backup /.env
/robots.txt

Pourquoi ce choix :

Outil universel facile
d'utilisation



Vulnérabilités web

6700+ tests
Headers, misconfig

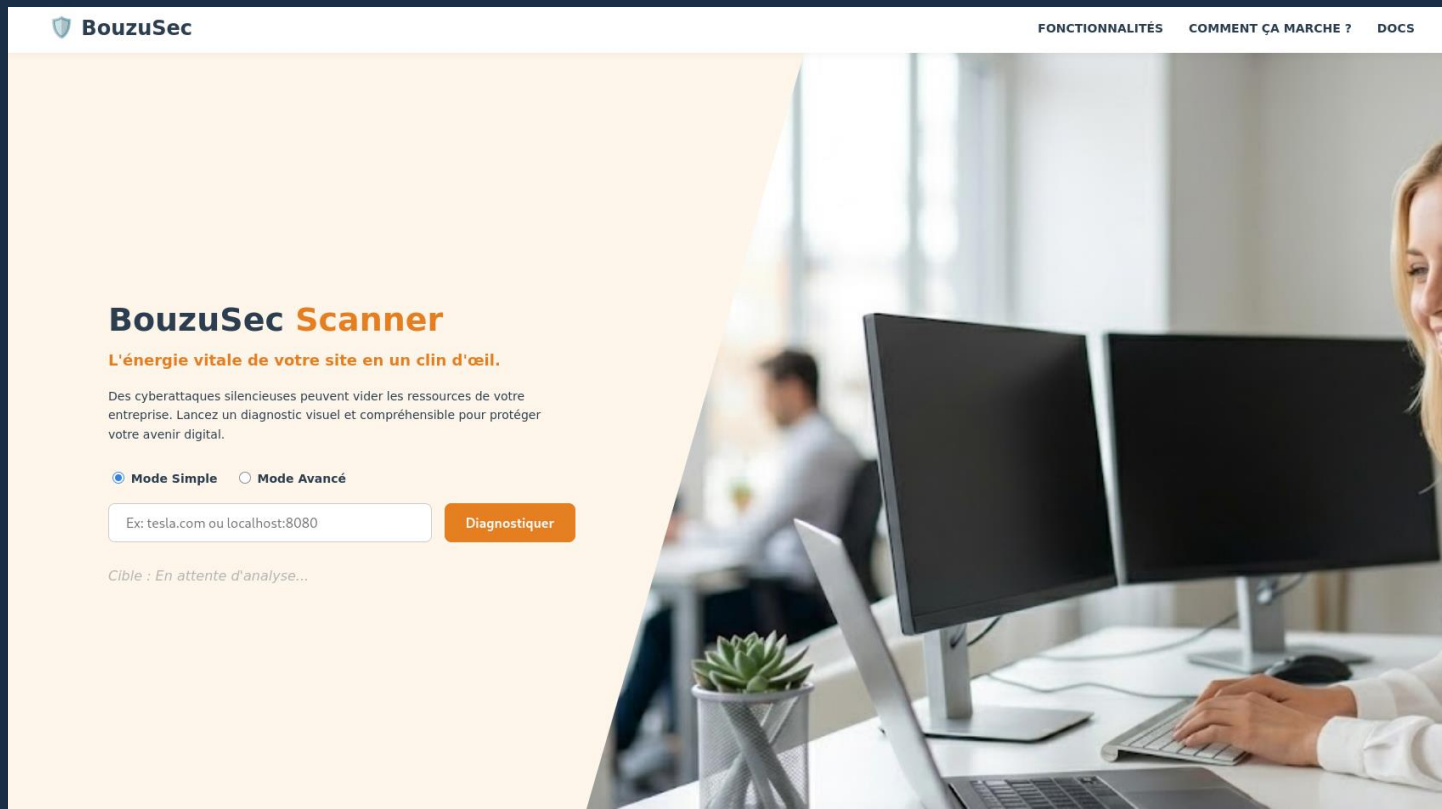
Ce qu'il trouve :

Headers manquants
Vulnérabilités connues

Pourquoi ce choix :

6700+ tests intégrés sans
licence

MODE SIMPLE – Diagnostic Rapide



Interface BouzuSec – Mode Simple Sélectionné



Public cible

Le dirigeant – Aucune compétence technique / Vérification de routine

Durée

~ 30 secondes à 1 minute maximum

Outils actifs

Whois – WhatWeb – Nmap (top 100 ports) – Nikto (scan rapide)

Fonctionnement

Cible uniquement les vulnérabilités les plus courantes (Top 10 OWASP)

Rapport

PDF 2 pages : jauge + radar + recommandations

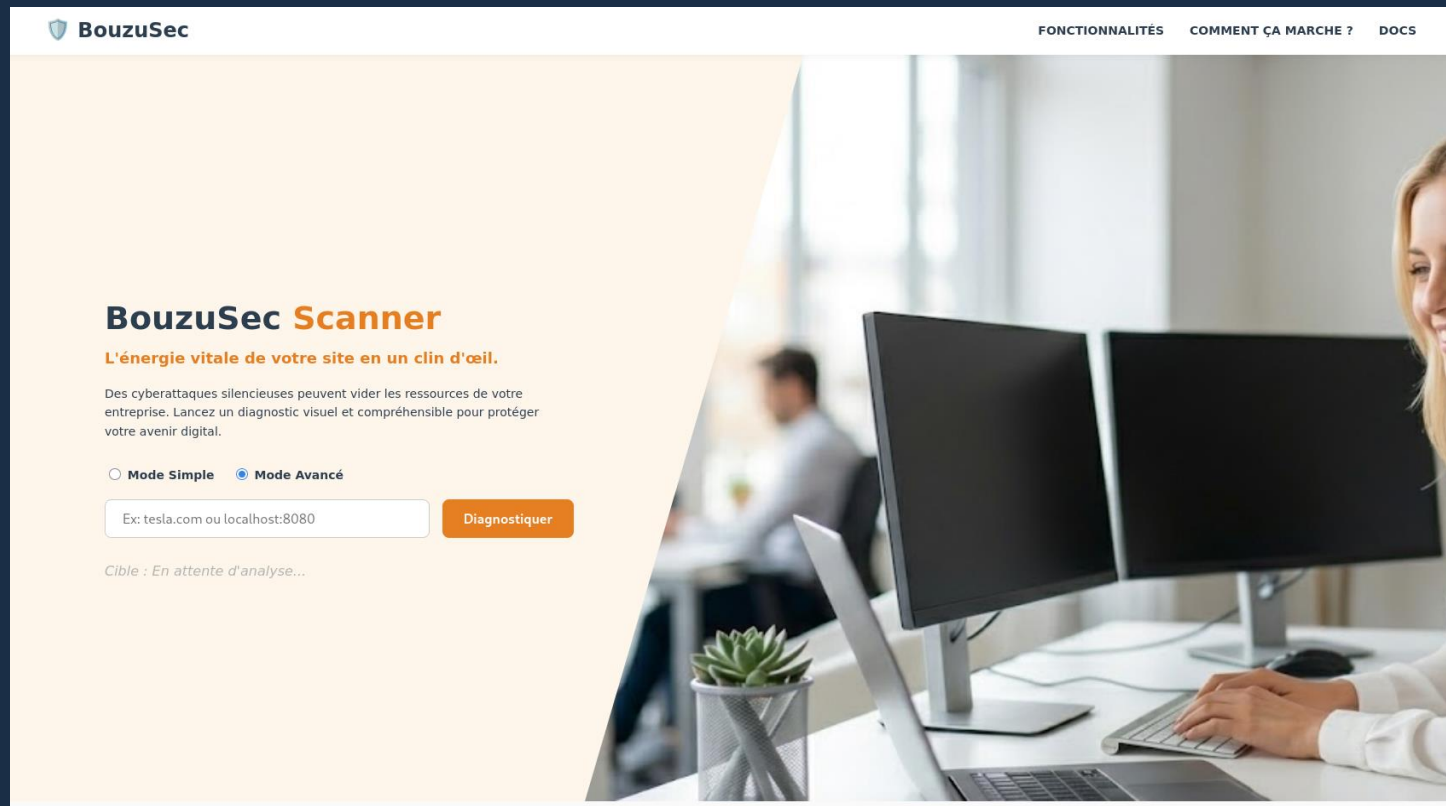
SYNTHÈSE DU NIVEAU DE RISQUE



Niveau d'énergie vitale : 71 %

Évaluation ANSSI : RISQUE MODÉRÉ (Note : 7.1/10)

MODE AVANCE – L'audit Technique Exhaustif



Interface BouzuSec – Mode Avancé Sélectionné



Public cible

Equipe techniques, DSI, Administrateurs système

Durée

~ 2 minutes à 5 minutes maximum (Analyse approfondie)

Outils actifs

Whois – WhatWeb – Nmap (65535 ports) – Nikto – GoBuster

Fonctionnement

Les outils se configurent et se lancent dynamiquement en fonction des technologies découvertes en amont

Rapport

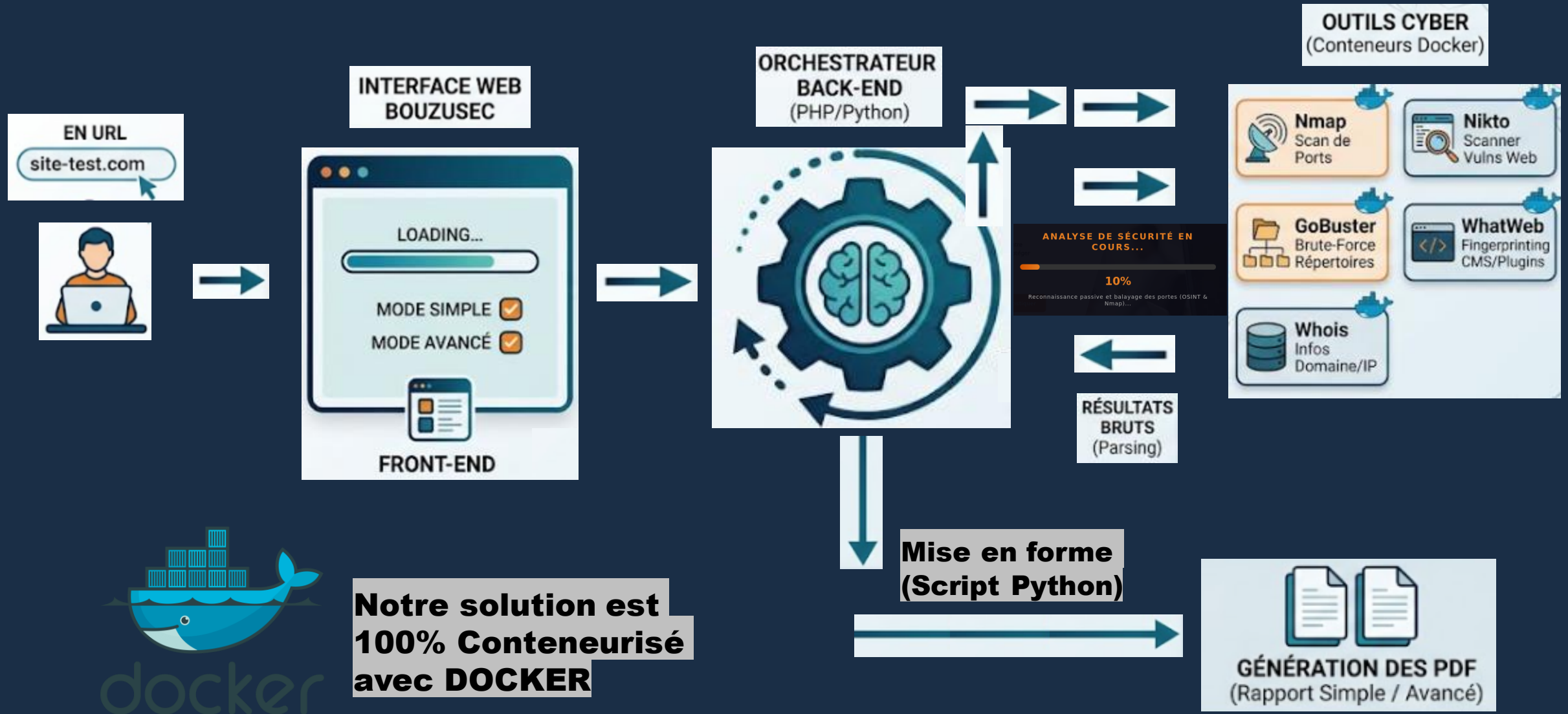
PDF complet (~ 7 pages), cartographie détaillée, logs, sorties brutes

SYNTHÈSE DU NIVEAU DE RISQUE



Niveau d'énergie vitale : 42 %
Évaluation ANSSI : RISQUE ÉLEVÉ (Note : 4.2/10)

ARCHITECTURE – Une plateforme Centralisée et Conteneurisée



GENERATION DES PDF : De la Donnée brute au Rapport Clair

Rapport Simple

2-3 pages / Pour un non connaisseur

Page 1 : Dashboard

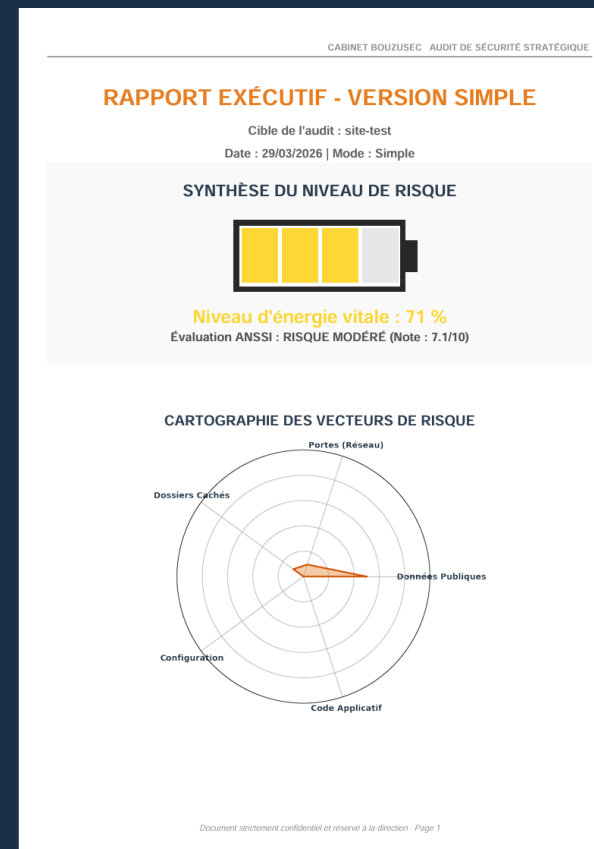
Jauge batterie + radar 5 axes + niveau ANSSI

Page 2 : Vue d'ensemble

Résumé des 5 axes + recommandations prioritaires

Objectif : décision en 2 minutes

Le dirigeant comprend immédiatement son niveau de risque et les actions à mener

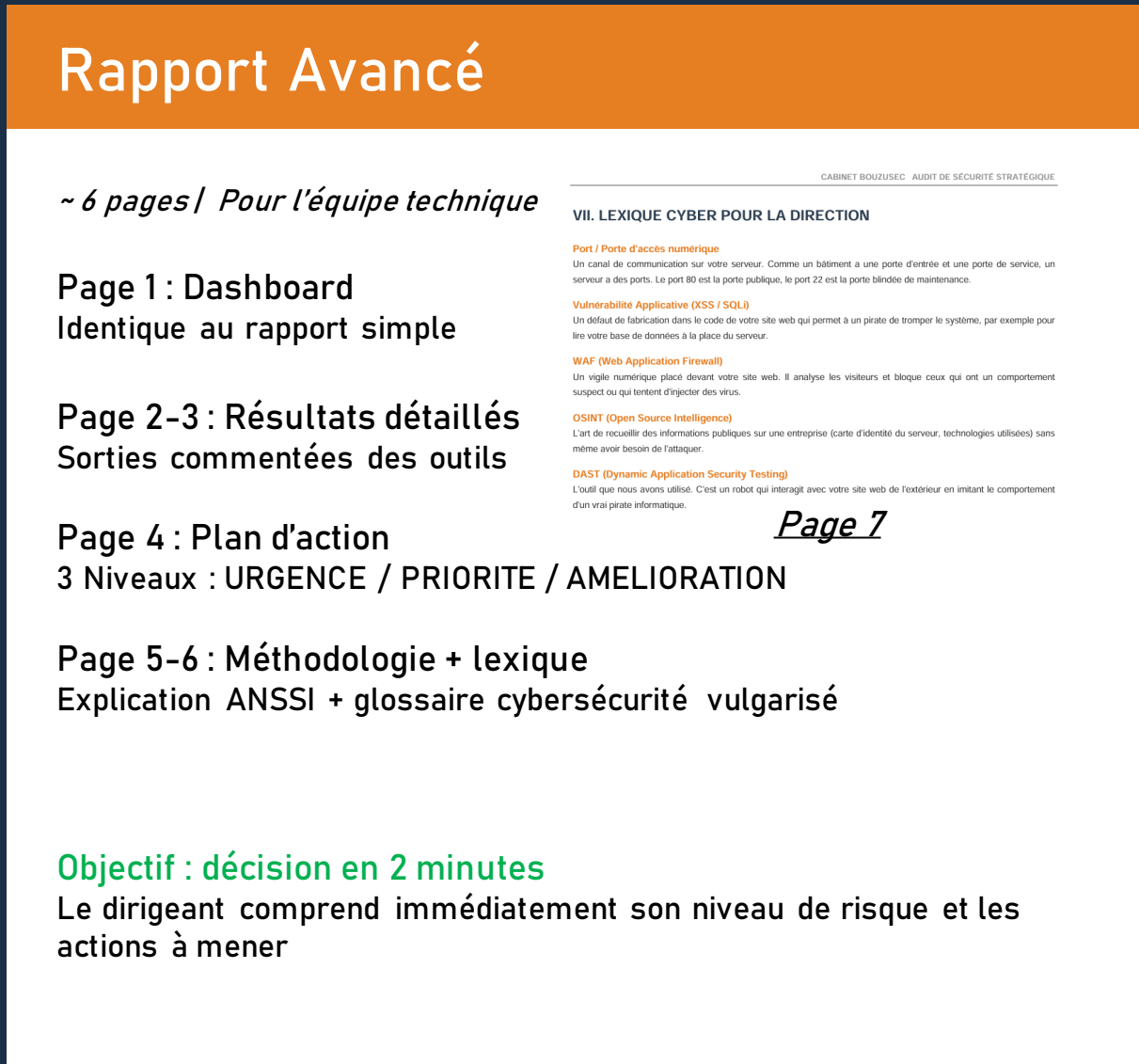
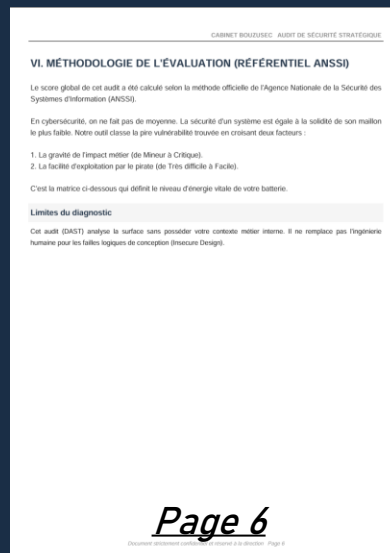
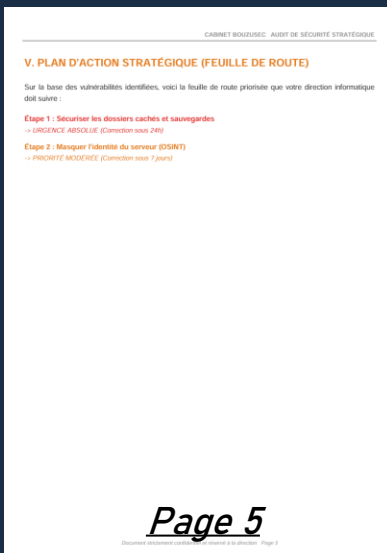
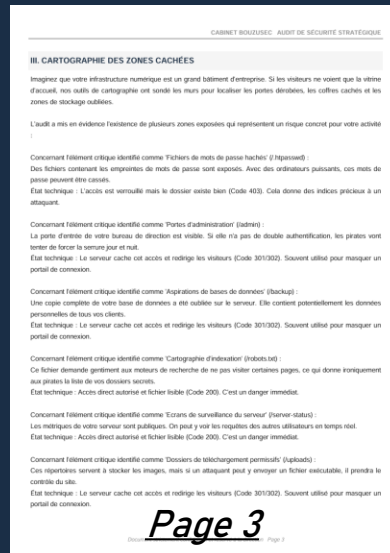
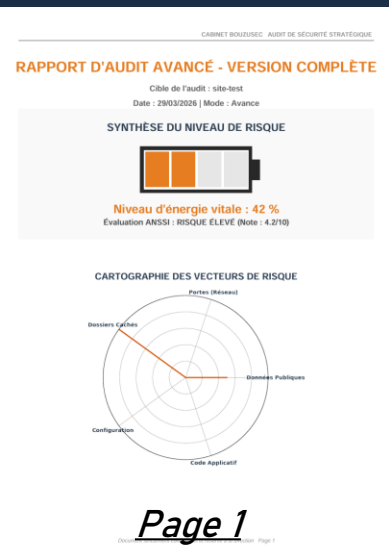


Page 1



Page 2

GENERATION DES PDF : De la Donnée brute au Rapport Clair



DEMONSTRATION – Scan en Direct sur un site-test



BouzuSec Scanner

Conclusion

- Réponse à 100% à l'appel d'offre
 - Vulgarisation réussie
 - Standard ANSSI
 - Génération PDF automatisée
 - Déploiement Simplifié
- De futurs implémentations

BouzuSec Scanner

L'énergie vitale de votre site en un clin d'œil.

Des cyberattaques silencieuses peuvent vider les ressources de votre entreprise. Lancez un diagnostic visuel et compréhensible pour protéger votre avenir digital.

☒ Mode Simple ☐ Mode Avancé

Ex: tesla.com ou localhost:8080

Diagnostiquer

✓ Diagnostic terminé !

L'audit en boîte noire de **site-test** a été généré avec succès.

📄 Rapport Simple

🔍 Rapport Avancé